Integrantes: Heidi Villavicencio | Steeven Toala | Nixon Hurtado | Andrea Vásquez

1. TÍTULO

Denominación del Entregable: Autenticación y Autorización de Usuarios (JWT & RBAC) – Código EDT: 3.3

2. INTRODUCCIÓN

La seguridad y confidencialidad de la información docente exige mecanismos estrictos de identificación, autenticación y control de acceso. En esta actividad se implementó la arquitectura de seguridad del backend en Express v5 mediante JSON Web Tokens (JWT) y el modelo de Control de Acceso Basado en Roles (RBAC). Se establecieron políticas rigurosas de firma HMAC-SHA256, expiración controlada de tokens de 2 horas, almacenamiento seguro de contraseñas con salado criptográfico bcrypt y decoradores de autorización para restringir rutas sensibles.

3. OBJETIVO

3.1. Objetivo General

Implementar el subsistema de autenticación y autorización basado en JWT y RBAC en el backend Express v5, garantizando la seguridad en el acceso a recursos del sistema SIGE.

3.2. Objetivos Específicos

- Implementar el endpoint seguro de inicio de sesión con validación de contraseñas bcrypt.
- Diseñar y firmar tokens JWT con claims de usuario, carrera y rol institucional.
- Construir el middleware `authMiddleware` y el interceptor de roles `authorizeRole([roles])`.

4. ALCANCE

4.1. Límites del Entregable (In-Scope)

- Endpoints `POST /api/auth/login`, `GET /api/auth/profile` y `POST /api/auth/refresh`.
- Matriz de permisos RBAC para los 4 roles del sistema.

4.2. Exclusiones (Out-of-Scope)

- Integración con directorio activo LDAP central universitario (diseñado con autenticación local JWT).

5. DEFINICIONES

- **JWT (JSON Web Token):** Estándar abierto (RFC 7519) para transmitir de forma segura información compacta y autónoma entre partes en formato JSON.
- **RBAC (Role-Based Access Control):** Enfoque de seguridad para restringir el acceso al sistema únicamente a los usuarios autorizados según su rol.
- **Bcrypt:** Función de derivación de claves basada en el cifrado Blowfish con sal aleatoria para almacenar contraseñas de forma irreversible.

6. RESPONSABILIDADES

- **Nixon Hurtado / Steeven Toala (Responsables EDT 3.3):** Implementación de endpoints de seguridad, generación de JWT y middlewares RBAC.
- **Andrea Vásquez (Frontend):** Integración del almacenamiento seguro del token en sesión del cliente.
- **Ing. Paulo Torres (Docente Evaluador):** Aprobación de la política de seguridad y roles.

7. NORMATIVA LEGAL Y TÉCNICA

- **RFC 7519: JSON Web Token (JWT).**
- **OWASP Top 10 API Security Risks: Broken Authentication & Authorization.**

8. MÉTODO, POLÍTICAS Y CONTENIDOS

Se utilizó autenticación Bearer Token en encabezados HTTP. En la Figura 1 se presenta el flujo de autenticación JWT y control RBAC.

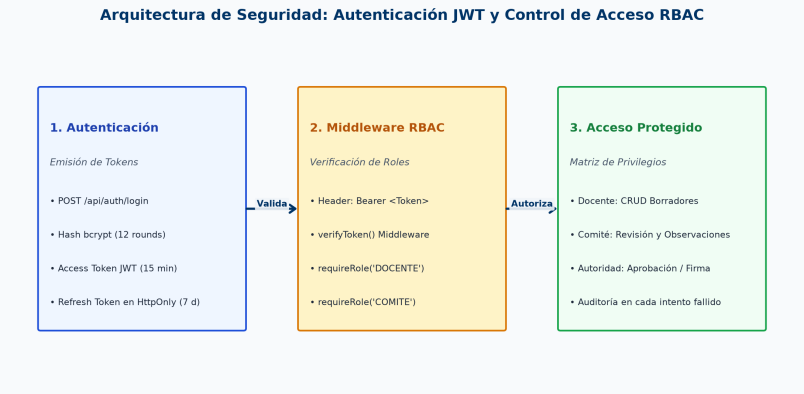


Figura 1: Arquitectura de Seguridad: Autenticación JWT y Control de Acceso RBAC.

9. DESCRIPCIÓN DE ACTIVIDADES

9.1. Matriz de Control de Acceso Basado en Roles (RBAC)

Operación / Endpoint	Docente	Coord. Área	Coord. Carrera	Admin SGC	
Crear / Editar Plan Borrador	Permitido	Denegado	Denegado	Permitido	
Registrar / Editar Actividades	Permitido	Denegado	Denegado	Permitido	
Cargar Evidencias MinIO	Permitido	Denegado	Denegado	Permitido	
Estampar Firma Elaborador	Permitido	Denegado	Denegado	Denegado	
Registrar Observaciones	Denegado	Permitido	Permitido	Permitido	
Estampar Firma Revisor	Denegado	Permitido	Denegado	Denegado	
Estampar Firma Aprobador	Denegado	Denegado	Permitido	Denegado	
Exportar Salidas Oficiales	Permitido	Permitido	Permitido	Permitido	
Parametrizar Catálogos	Denegado	Denegado	Denegado	Permitido	

Tabla 1: Matriz de Permisos y Autorizaciones por Rol Institucional.

9.2. Estructura del Payload JWT

El token contiene claims estándar e institucionales: `sub` (UUID del usuario), `email`, `rol` ('DOCENTE', 'COORD_AREA', etc.), `carreraId`, `iat` y `exp` (duración exacta de 7,200 segundos).

10. FIRMAS DE RESPONSABILIDAD

ACCIÓN	NOMBRE Y CARGO	FIRMA	FECHA
Elaborado por:	Heidi Villavicencio Analista de Calidad / UI-UX		14/09/2026
Revisado por:	Steeven Toala Líder de Proyecto / Arquitecto		14/09/2026
Aprobado por:	Ing. Paulo Torres, Mg. Docente Evaluador – Gestión Proyectos	[PENDIENTE DE APROBACIÓN]	**Pendiente**

11. CONTROL DE CAMBIOS

Versión	Descripción del cambio	Responsable del cambio	Fecha de aprobación
1.0	Emisión inicial del entregable según EDT del Tablero Trello	Equipo de Proyecto SIGE	14/09/2026

12. ANEXOS

- **Anexo 1:** Pruebas de Rechazo de Tokens Expirados y Manipulados.